TECNOMARKET – Incident Response Report – INC2026-0222-22 – 22-02-2026

IDENTIFICACIÓN DEL INCIDENTE

ID del Incidente: INC2026-0222-22
Gravedad: Alta
Estado del Incidente: En análisis

Fecha: 22-02-2026

Área afectada: Administración

Sistema afectado: **ADM-04-HP-PD**

Método de Detección: Alerta de comportamiento anómalo generada por el sistema SIEM durante el monitoreo del SOC

DESCRIPCIÓN

La noche del **22 de febrero de 2026, a las 22:00 horas**, el **Centro de Operaciones de Seguridad (SOC)** de *Tecnomarket* detectó actividad no autorizada en la estación de trabajo **ADM-04-HP-PD**, ubicada dentro de la red local del edificio administrativo.

La alerta fue generada por el sistema SIEM tras detectar ejecución de comandos PowerShell con parámetros asociados a técnicas de evasión, los cuales explotaron una vulnerabilidad asociada a un **controlador desactualizado** del sistema. Como resultado, se observaron **indicadores compatibles con una escalada de privilegios**, con posible impacto sobre componentes de bajo nivel del sistema.

Inicialmente la actividad se limitó a la estación ADM-04-HP-PD; sin embargo, debido a la presencia del mismo modelo de hardware en otras estaciones del área administrativa, se consideró la posibilidad de exposición adicional.

La posible alteración del firmware podría permitir persistencia del atacante incluso después de reinstalar el sistema operativo.

En el momento de la detección no se contaba con evidencia concluyente sobre el alcance completo del compromiso, por lo que se inició un proceso de análisis preliminar.

ANÁLISIS PRELIMINAR

El análisis inicial sugiere que el incidente pudo originarse a partir de un correo electrónico de phishing dirigido a un usuario del área administrativa. El mensaje contenía un archivo de hoja de cálculo que incluía macros maliciosas diseñadas para ejecutar código en el sistema al ser habilitadas por el usuario.

Una vez activada la macro, se observó la ejecución de comandos de PowerShell con parámetros asociados a técnicas de evasión y ejecución en memoria, incluyendo la ejecución sin perfil del usuario, bypass de políticas de ejecución y la descarga remota de un payload desde infraestructura externa controlada por el atacante.

Estas acciones habrían permitido establecer un punto inicial de ejecución dentro del sistema comprometido.

Posteriormente, la actividad detectada sugiere la posible explotación de un controlador vulnerable del sistema, lo que podría permitir la escalada de privilegios y el acceso a componentes de bajo nivel del sistema operativo.

Con privilegios elevados, un atacante podría potencialmente interactuar con interfaces de firmware del hardware, incluyendo el firmware del sistema (UEFI/BIOS) y firmware asociado a controladores del dispositivo.

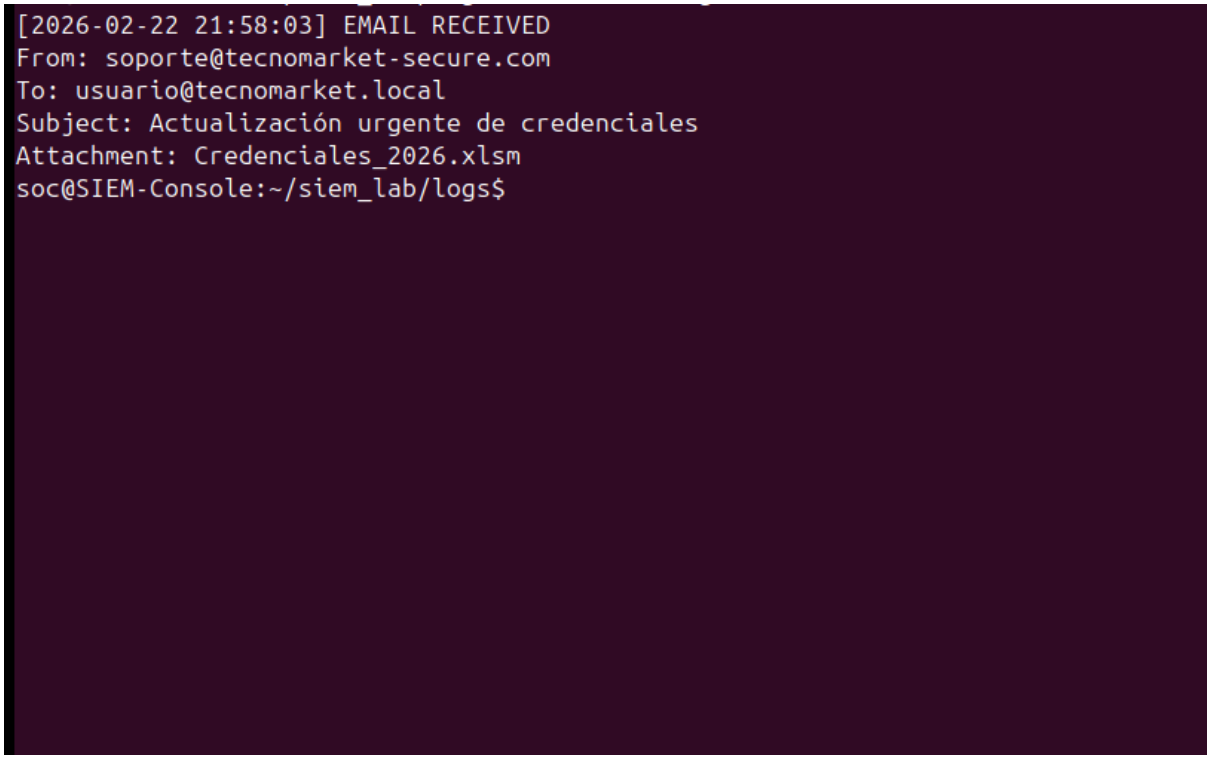
Debido a que múltiples estaciones de trabajo dentro del área administrativa utilizan el mismo modelo de hardware y controladores, no se descarta la posibilidad de que la vulnerabilidad pueda ser explotada en otros sistemas si el atacante logra realizar movimiento lateral dentro de la red.

La manipulación de firmware representaría un escenario de alta criticidad, ya que permitiría establecer mecanismos de persistencia que podrían sobrevivir incluso a la reinstalación del sistema operativo.

INDICADORES DE COMPROMISO

Nota: Los registros presentados en esta sección han sido generados en un entorno simulado con fines demostrativos, replicando estructuras y eventos típicos de un sistema SIEM en un escenario real.

Recepción de correo de phishing

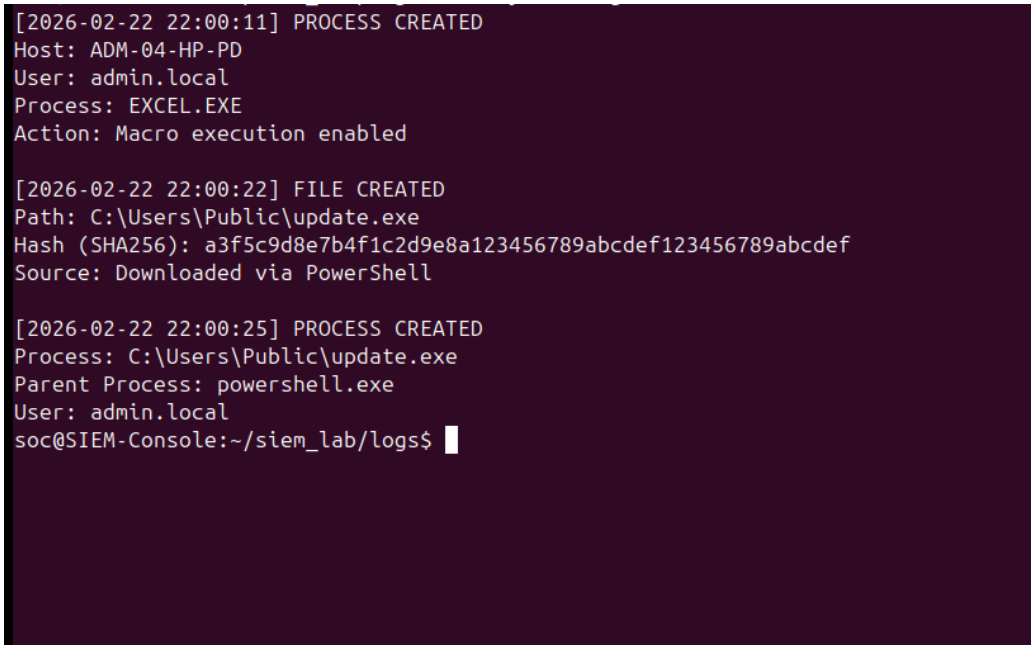


Descripción:
Se observa la recepción de un correo electrónico proveniente de la dirección soporte@tecnomarket-secure.com, dirigido a un usuario interno. El mensaje contiene un archivo adjunto en formato Excel (.xlsm), el cual incluye macros potencialmente maliciosas.

Análisis:
El uso de documentos con macros es una técnica ampliamente utilizada en campañas de phishing para ejecutar código en el sistema de la víctima una vez que el usuario habilita el contenido.

Relación con el incidente:
Este evento representa el vector de acceso inicial, mediante ingeniería social, que permitió la entrega del artefacto malicioso al sistema comprometido.

Ejecución de macro y actividad del payload



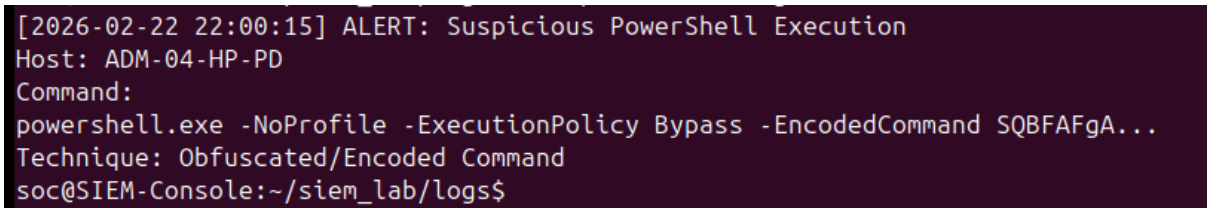
Descripción:
Se registran múltiples eventos en el host ADM-04-HP-PD, incluyendo la ejecución de EXCEL.EXE con macros habilitadas, la creación del archivo C:\Users\Public\update.exe y su posterior ejecución como proceso hijo de powershell.exe.

Análisis:
La secuencia observada evidencia la cadena de ejecución del ataque: el documento malicioso inicia la ejecución de código, descarga un binario y lo ejecuta en el sistema. La relación entre procesos confirma comportamiento típico de malware.

Relación con el incidente:

Estos eventos consolidan la ejecución del payload dentro del sistema comprometido, permitiendo al atacante establecer control inicial sobre el host.

Ejecución de PowerShell malicioso



Descripción:

Se identifica la ejecución de powershell.exe con parámetros como -NoProfile y -ExecutionPolicy Bypass, junto con un comando codificado.

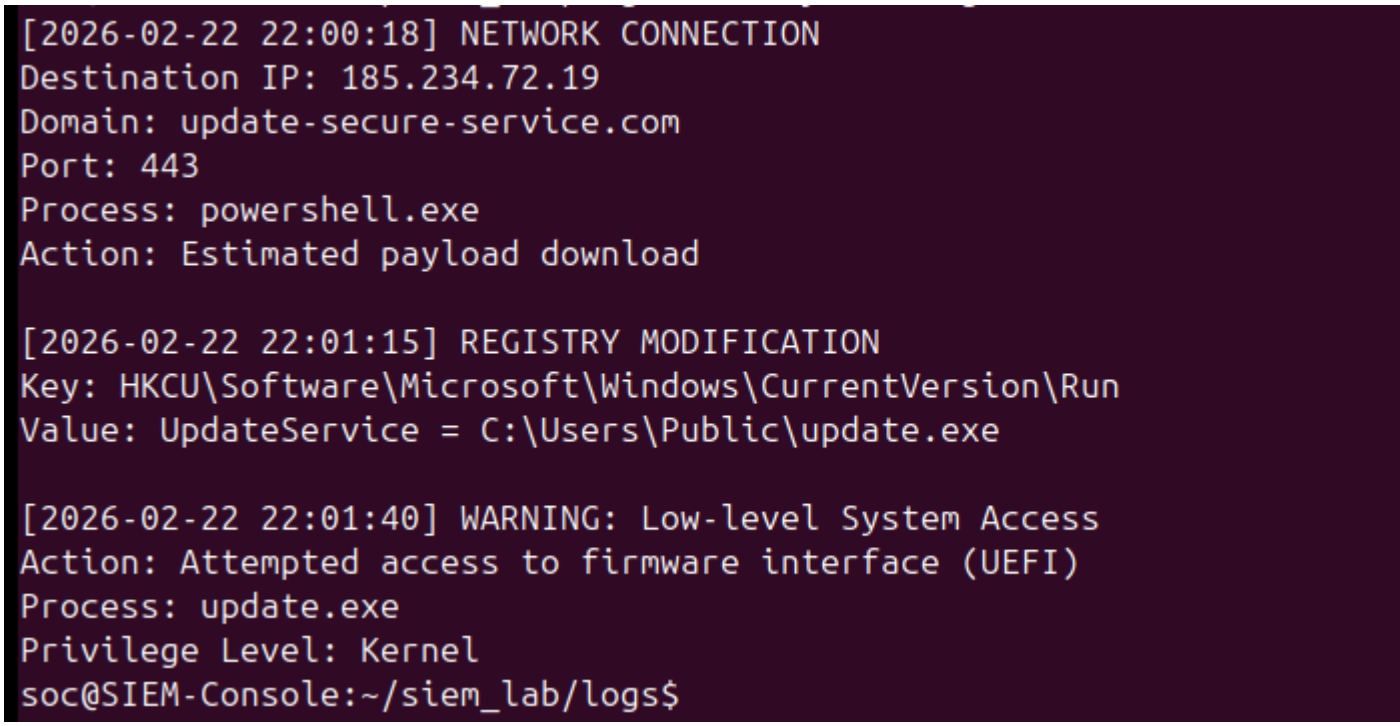
Análisis:

Estos parámetros son comúnmente utilizados para evadir controles de seguridad y ejecutar código sin restricciones. El uso de comandos codificados (EncodedCommand) indica ofuscación para dificultar su detección.

Relación con el incidente:

Este evento marca el inicio de la ejecución activa del ataque en memoria, derivado de la macro maliciosa contenida en el archivo de phishing.

Actividad de red y persistencia



Descripción:

Se observan eventos que incluyen una conexión saliente hacia una dirección IP externa asociada a la descarga de un payload, así como la modificación de una clave de registro (Run) para la ejecución automática de un binario. También se detectan intentos de acceso a interfaces de firmware del sistema.

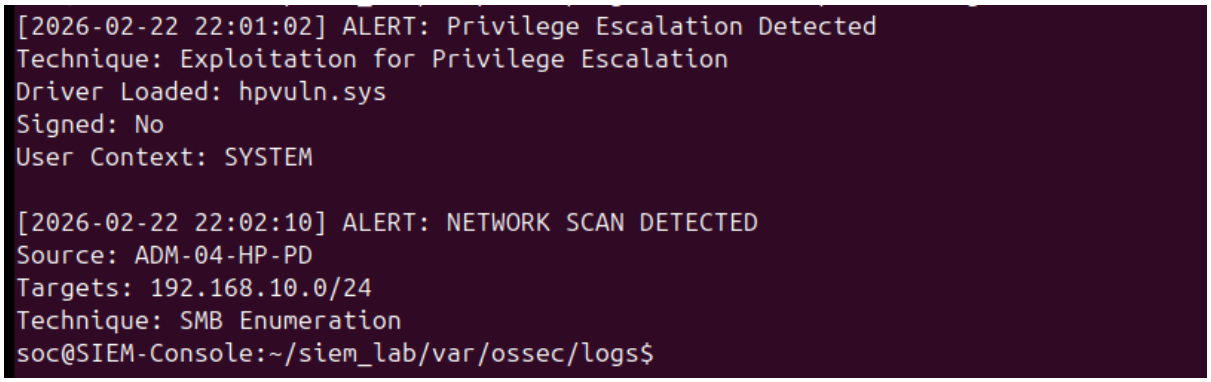
Análisis:

La conexión de red indica comunicación con infraestructura controlada por el atacante, mientras que la modificación del registro evidencia un mecanismo de persistencia. El acceso a firmware sugiere un intento avanzado de mantener control a bajo nivel.

Relación con el incidente:

Estos eventos reflejan las fases de descarga de herramientas, establecimiento de persistencia y posible escalamiento del impacto del ataque.

Detección por el SIEM y actividad sospechosa



Descripción:
Se registran alertas generadas por el sistema SIEM que indican una posible escalada de privilegios mediante la carga de un controlador vulnerable (hpvuln.sys), así como actividad de escaneo de red desde el host comprometido.

Análisis:
La detección de escalada de privilegios confirma que el atacante obtuvo acceso elevado al sistema. El escaneo de red sugiere intentos de identificar otros sistemas dentro de la red para propagarse.

Relación con el incidente:
Estas alertas evidencian la evolución del ataque hacia fases más avanzadas, incluyendo control total del sistema y posible movimiento lateral dentro de la red.

CONTENCIÓN

Se procedió al aislamiento de la estación afectada de la red corporativa mediante la desconexión de su interfaz de red, con el objetivo de prevenir la comunicación con infraestructura externa y evitar la posible propagación del incidente.

Debido a la criticidad del incidente, el riesgo potencial de propagación a otros sistemas con características similares y la posibilidad de persistencia a nivel de firmware, se priorizó la contención inmediata del sistema afectado sobre la recolección extendida de inteligencia en vivo.

No obstante, se consideró la preservación de evidencia disponible antes de aplicar medidas de erradicación, con el fin de permitir un análisis forense posterior.

Tras la detección de actividad sospechosa en un equipo del área administrativa, se implementaron medidas de contención orientadas a limitar el alcance del incidente y prevenir el movimiento lateral dentro de la organización. Dado que el compromiso se originó en un endpoint, las acciones se centraron en la contención del dispositivo afectado, la protección de las identidades asociadas y la verificación de accesos a servicios críticos.

Dado que el compromiso involucró ejecución de código en un endpoint corporativo, se consideró el riesgo de exposición de credenciales del usuario afectado, por lo que se aplicaron medidas de contención sobre identidades y accesos asociados.

Se aplicaron controles de seguridad en los sistemas directamente relacionados con el usuario comprometido, incluyendo herramientas de protección endpoint, servicios de identidad y plataformas de productividad y negocio. Adicionalmente, se mantuvo monitoreo activo sobre servicios en la nube para detectar posibles accesos no autorizados, sin aplicar medidas disruptivas en ausencia de evidencia de compromiso.

Estas acciones permitieron contener el incidente de manera controlada, reduciendo el riesgo de propagación y preservando la integridad de los sistemas críticos.

Controles de contención aplicados por servicio

Kaspersky Endpoint Security

- Aislamiento del endpoint comprometido de la red
- Terminación de procesos sospechosos
- Cuarentena de archivos maliciosos detectados
- Ejecución de escaneo completo del sistema

Azure Active Directory Domain Services

- Deshabilitación temporal de la cuenta del usuario comprometido
- Revocación de sesiones activas
- Forzado de restablecimiento de contraseña
- Revisión de intentos de autenticación recientes

Microsoft 365 Business Standard

- Revocación de sesiones activas del usuario

- Revisión y eliminación de reglas de correo sospechosas
- Análisis de correos enviados para identificar posible propagación
- Bloqueo temporal de la cuenta en caso de actividad anómala

Odoo ERP & CRM

- Suspensión temporal del acceso del usuario comprometido
- Revisión de actividad reciente (transacciones, modificaciones)
- Validación de integridad de datos críticos
- Monitoreo de accesos posteriores al incidente

Servicios en Microsoft Azure (App Service, Functions, SQL Database, Static Web Apps)

- Revisión de logs de acceso recientes
- Monitoreo de intentos de autenticación sospechosos
- Validación de integridad de servicios y disponibilidad
- Sin aplicación de medidas de contención al no evidenciar compromiso

Adicionalmente, se implementaron medidas de contención orientadas a proteger los activos de información almacenados localmente en el endpoint comprometido.

Se realizó la identificación y protección de archivos y documentos potencialmente sensibles, aplicando restricciones de acceso y monitoreo sobre actividades recientes que pudieran indicar manipulación o exfiltración de información. Asimismo, se llevaron a cabo respaldos preventivos de información crítica para garantizar su disponibilidad e integridad.

En el caso de datos estructurados almacenados localmente, como hojas de cálculo y bases de datos, se verificó la integridad de los archivos relevantes y se limitó temporalmente su acceso, con el fin de reducir el riesgo de alteración o fuga de información.

Dado el posible acceso a información de clientes y partes interesadas, se evaluó el riesgo de exposición de datos personales, implementando medidas de monitoreo reforzado y control de accesos, en cumplimiento de las obligaciones regulatorias aplicables, como la LFPDPPP.

Respecto a información financiera, se aplicaron controles de revisión de accesos recientes y validación de integridad de los registros, así como monitoreo de posibles actividades anómalas.

Finalmente, considerando la ejecución de código en el endpoint comprometido, se asumió el posible compromiso de credenciales almacenadas en navegadores, por lo que se procedió a la revocación de sesiones activas, restablecimiento de contraseñas y eliminación de credenciales almacenadas, reduciendo el riesgo de acceso no autorizado a otros sistemas corporativos.

Las acciones de contención se ejecutaron siguiendo el principio de mínimo impacto operativo, priorizando el aislamiento del vector inicial y la protección de identidades. No se identificaron indicios de compromiso en servicios críticos en la nube, por lo que se mantuvo un enfoque de monitoreo reforzado en dichos activos.

RECUPERACIÓN

Antes de la reincorporación del sistema a la red corporativa, se implementaron controles de monitoreo reforzado sobre el endpoint recuperado, con el objetivo de detectar posibles comportamientos anómalos residuales.

Se habilitó la recolección y análisis continuo de logs mediante el sistema SIEM, junto con mecanismos de detección en el endpoint orientados a identificar actividad sospechosa. Adicionalmente, el equipo fue ubicado temporalmente en un segmento de red controlado, limitando su comunicación únicamente a los servicios necesarios para su operación.

Se aplicaron restricciones de privilegios y controles de ejecución sobre el sistema, con el fin de reducir el riesgo de explotación mediante vectores previamente observados. Asimismo, se mantuvo supervisión sobre accesos, uso de credenciales y cambios en el sistema, permitiendo una detección temprana ante cualquier indicio de compromiso persistente.

Para su reincorporación a la red corporativa, el sistema fue sometido a un proceso controlado y gradual, en el cual se validó previamente su estado mediante la revisión

de eventos recientes y la ausencia de alertas de seguridad. Inicialmente, el equipo fue integrado en un entorno restringido, manteniendo políticas de filtrado de tráfico y monitoreo activo de comunicaciones salientes.

Durante esta fase, se aplicaron controles adicionales de supervisión, incluyendo el seguimiento de conexiones de red, ejecución de procesos y actividad del usuario, con el fin de identificar comportamientos atípicos. Una vez transcurrido el periodo de observación sin detección de anomalías, se autorizó su reintegración completa al entorno operativo, manteniendo monitoreo reforzado como medida preventiva.

LECCIONES APRENDIDAS

Fallos identificados

El análisis del incidente permitió identificar diversas deficiencias en los controles de seguridad implementados. En primer lugar, se evidenció la ausencia de mecanismos avanzados de filtrado de correo electrónico, lo que permitió la entrega de un mensaje de phishing al usuario final, indicando la falta de soluciones como Secure Email Gateway.

Asimismo, se identificó una falta de concienciación en el usuario afectado, quien habilitó contenido malicioso dentro de un archivo recibido, evidenciando la necesidad de fortalecer los programas de capacitación en ciberseguridad.

A nivel técnico, el antivirus tradicional no detectó la amenaza al no coincidir con firmas conocidas, mientras que, aunque el sistema EDR generó alertas de comportamiento anómalo, estas no fueron correctamente gestionadas, derivando en un falso negativo por parte del analista del SOC (error de clasificación).

Adicionalmente, se detectó una deficiente gestión de vulnerabilidades, ya que el sistema afectado contaba con componentes desactualizados, incluyendo controladores y firmware, lo que facilitó la explotación.

Finalmente, la homogeneidad del hardware dentro del área administrativa incrementa el riesgo sistémico, al permitir que una misma vulnerabilidad pueda ser explotada en múltiples equipos.

Áreas de mejora

Se identificó la necesidad de fortalecer la gestión de parches y actualizaciones, estableciendo políticas formales y periódicas para la actualización de sistemas operativos, controladores y firmware.

Asimismo, se recomienda la implementación de controles de seguridad adicionales, incluyendo soluciones de detección y respuesta en endpoints (EDR), monitoreo de red (NDR) y filtrado avanzado de correo electrónico.

A nivel operativo, se sugiere optimizar los procesos del SOC, incluyendo la revisión de procedimientos de análisis de alertas, así como la implementación de medidas para reducir la fatiga operativa del personal, como la rotación adecuada de turnos.

Finalmente, se destaca la necesidad de fortalecer la capacitación de los usuarios en materia de ciberseguridad, especialmente en la identificación de correos de phishing y el manejo seguro de archivos adjuntos.

Cambios organizacionales

Como resultado del incidente, se establecerá una política de actualización periódica de sistemas, definiendo ciclos regulares para la aplicación de parches y actualizaciones críticas.

Se implementarán programas de capacitación en ciberseguridad dirigidos a todos los empleados, con el objetivo de reducir el riesgo asociado al factor humano.

Asimismo, se evaluará la adopción de nuevas soluciones de seguridad en función del apetito de riesgo de la organización, priorizando la protección de endpoints críticos y la detección temprana de amenazas.

Actualizaciones a procesos y controles

Se procederá a la actualización de los playbooks de respuesta a incidentes, incorporando escenarios relacionados con vulnerabilidades de firmware y técnicas de persistencia avanzada.

Adicionalmente, se revisarán y ajustarán los procedimientos de respuesta a incidentes, así como los controles de seguridad existentes, con el fin de mejorar la capacidad de detección, contención y recuperación ante incidentes similares.